

January 2026 CSE 406: Cyber Security Sessional

Online 2: Ethical Hacking

Section: B2

Time: 40 minutes

Ethical-use warning

This is an intentionally vulnerable, isolated teaching environment. Use the techniques in this assignment only against the supplied local containers. Never test an application, account, or network without explicit authorization. The same actions against a real service may be unethical and illegal.

Objective

The university operates two systems: a **Student Portal** containing student information and marks, and **Student Chat**, used by students to communicate. Acting only as the designated attacker account, fully compromise the pair as follows:

Discover the structure of the Student Portal database and extract every student's ID and total marks, then calculate the average total marks across all students. Then, through the same vulnerable login input, use a stacked statement to persist a browser payload in the **victim's** own record. When the victim next logs into the Student Portal and views their profile, the payload must execute in the victim's browser and perform a CSRF against Student Chat. The resulting message must be posted using the victim's own Chat account and must state the correct average total marks of all students.

Environment Setup

The Moodle archive contains `B2-images.tar`, `compose.yaml`, and this specification. Internet access is not required after download. From the directory containing those files, run:

```
seed@ubuntu:~$  
  
docker load --input B2-images.tar  
docker compose up -d  
docker compose ps
```

Wait until all three services are running. Open:

- Student Portal: `http://localhost:8000`
- Student Chat: `http://localhost:8001`

To reset every database change, session, and chat message and return to the original seeded state:

```
seed@ubuntu:~$  
  
docker compose down  
docker compose up -d
```

The 40-minute limit includes image loading and environment startup. Raise your hand immediately if Docker reports an infrastructure error before either page opens.

Credentials

Role	Student ID	Student Portal login	Student Chat login
Attacker	9900001	tahsin.talukder / talukder-99	tahsin.talukder / chat-Tahsin-99
Victim	9900002	rownak.bhuiyan / bhuiyan-99	rownak.bhuiyan / chat-Rownak-99

Tasks and Marks

The core assignment is worth 10 marks. One bonus mark is available.

1. **Student enumeration (2 marks):** Use SQL Injection to enumerate the database and retrieve the student ID of every student.
2. **Marks extraction (2 marks):** Use SQL Injection to retrieve the total marks of every student and correctly calculate their average.
3. **Victim Stored XSS (2 marks):** Use SQL Injection with a stacked statement to place a malicious script into the **victim's** own `last_name`. The script must execute when the victim views their own Student Portal profile.
4. **XSS to CSRF (2 marks):** Demonstrate that the victim's browser automatically submits a request to Student Chat purely as a consequence of the stored XSS.
5. **Victim Chat message (2 marks):** Demonstrate that the resulting message is created under the victim's own Student Chat account, states the correct average total marks of all students, and was generated by the XSS to CSRF chain rather than posted manually by the attacker.
6. **Bonus - cover your tracks (+1):** Discover the forensic trail left by Student Portal login submissions and, through the same injection channel, delete only the trail attributable to the attacker account. Evidence belonging to every other student must remain intact.

Restrictions

- All injection, extraction, and cleanup used for grading must be issued through the Student Portal login form while acting as the attacker account, **9900001**. Direct database edits do not earn marks.
- The attacker must not log into the victim's Student Chat account, use the attacker's own Chat account for the final message, or insert into the Chat database directly or through SQL Injection. The final message must be produced by the victim's own browser and session.
- The victim credentials are supplied only so you can confirm the chain from the victim's point of view.
- Do not attack anything outside the supplied local environment.
- Do not disrupt another student's workstation or containers.

Submission

Create a plain-text file named with your seven-digit student ID, for example 2105XXX.txt. For every graded stage, include:

1. the exact value or payload submitted;
2. the application, field, and account where it was submitted;
3. the observed result, all extracted student IDs and marks, and your computed average; and
4. the ordered steps needed to reproduce the final Student Chat message.

Submit only this text file through Moodle. Payloads without their input location or without enough context to reproduce the attack may not receive credit.